AUTHENTICATION & AUTHORIZATION

PPRESENTASI BY KELOMPOK 2

LET'S START

A presentation is a formal or informal communication method that involves conveying information, ideas, or a message to an audience.

PENGERTIAN &
KONSEP MATERI
LEARN MORE

AUTHENTICATION (OTENTIKASI)

Proses memverifikasi identitas pengguna atau sistem untuk memastikan bahwa mereka memang benar-benar pihak yang diakui. Pertanyaan utamanya adalah: "Siapa Anda?" (contoh: login menggunakan username dan password, OTP, atau pemindaian sidik jari).

READ MORE

AUTHORIZATION (OTORISASI)

Proses menentukan hak akses atau izin yang dimiliki oleh identitas terotentikasi tersebut. Pertanyaan utamanya adalah: "Apa yang boleh Anda lakukan?" (contoh: pembatasan akses pengguna biasa agar tidak bisa menghapus tabel basis data).

READ MORE

FUNGSI DAN TUJUAN DALAM KEAMANAN BASIS DATA

LEARN MORE

AUTHENTICATION

Berfungsi sebagai filter atau garda terdepan untuk menyaring siapa saja yang boleh masuk ke dalam lingkungan sistem basis data. Tujuannya adalah untuk mencegah akses dari pihak luar yang tidak dikenal, mencegah penggunaan identitas palsu, serta memastikan bahwa setiap aktivitas yang masuk ke dalam sistem terikat pada identitas pengguna yang valid.

LEARN MORE

AUTHORIZATION

Berfungsi mengontrol pembatasan akses (access control) secara mendalam setelah pengguna masuk ke dalam sistem basis data. Tujuannya adalah menerapkan prinsip integritas dan kerahasiaan (confidentiality), mencegah terjadinya modifikasi atau penghapusan data secara tidak sah oleh pihak internal, serta meminimalkan dampak kerusakan jika salah satu akun pengguna berhasil dikompromikan.

LEARN MORE

CONTOH KASUS

Kasus 1 — Akun Karyawan Nonaktif Masih Aktif (Authentication Breakdown): Seorang mantan staf IT sebuah perusahaan finansial masih memiliki kredensial akun database administrator yang belum dicabut. Karena tidak ada sistem otentikasi berkala atau integrasi Single Sign-On (SSO) yang mencabut akses otomatis saat pengunduran diri, mantan karyawan tersebut dapat masuk kembali ke database utama dari luar jaringan.

Kasus 2 — Esplikasi Hak Akses / Privilege Escalation (Authorization Bypass): Seorang pengguna dengan peran akun staf kasir biasa memanfaatkan celah keamanan pada aplikasi Web/API. Dengan mengubah parameter angka ID pada URL atau kueri (parameter tampering), staf tersebut mampu mengakses dan mengubah tabel gaji manajerial di dalam basis data, padahal otorisasi di level database tidak membatasi perintah UPDATE untuk peran kasir.

Kasus 3 — Serangan Credential Stuffing dan Brute Force (Authentication Failure): Peretas menggunakan bot otomatis untuk mencoba ratusan ribu kombinasi kata sandi dan nama pengguna hasil kebocoran data di situs lain ke portal basis data perusahaan. Tanpa adanya pembatasan percobaan login (rate limiting) atau otentikasi dua faktor (MFA), peretas akhirnya menemukan satu kombinasi akun yang cocok dan masuk ke dalam sistem.

CARA PENCEGAHAN DAN PENANGANANNYA

LEARN MORE

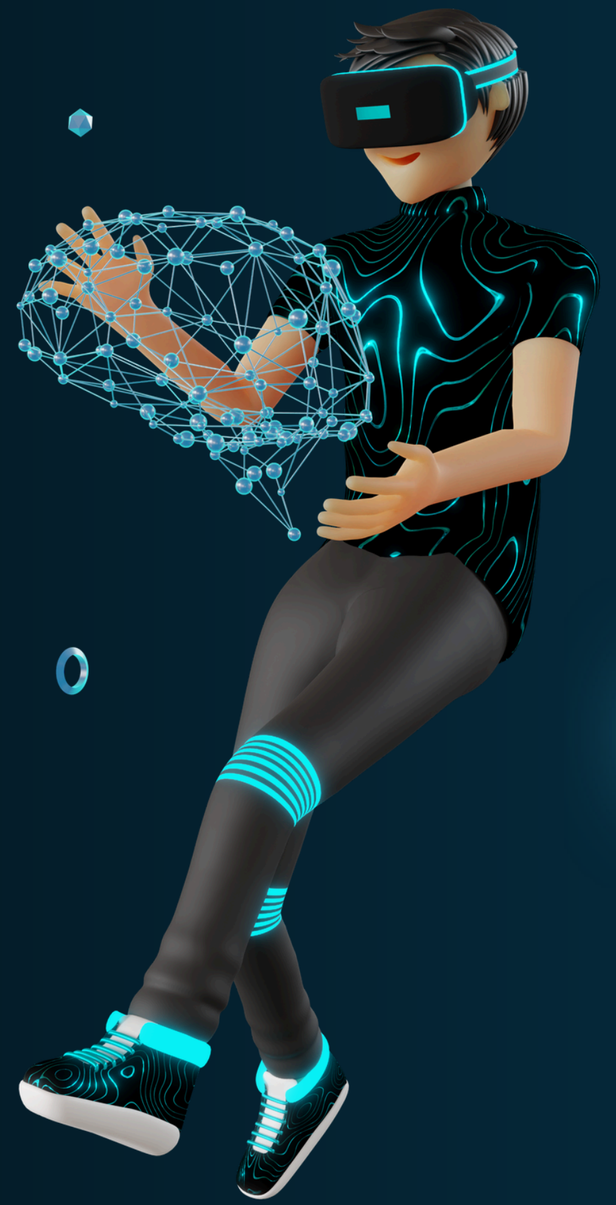
AUTHENTICATION

Penerapan MFA/2FA: Mewajibkan penggunaan Multi-Factor Authentication (seperti TOTP dari aplikasi authenticator atau token fisik) selain kata sandi.

Pengamanan Kredensial: Mengenkripsi seluruh kata sandi di dalam basis data menggunakan algoritma hashing yang kuat dan bertakar garam (salted hash) seperti Argon2 atau bcrypt, bukan teks biasa (plain text).

Manajemen Akses Identitas: Menerapkan pembatasan batas percobaan login (rate limiting / IP blocking) dan pemutusan sesi otomatis (session timeout) jika pengguna tidak aktif.

LEARN MORE



AUTHORIZATION

Prinsip Least Privilege: Memberikan hak akses sekecil dan seperlunya saja sesuai deskripsi pekerjaan pengguna. Jika seorang pengguna hanya perlu melihat laporan, berikan hak akses SELECT dan melarang INSERT, UPDATE, atau DELETE.

RBAC (Role-Based Access Control): Mengelompokkan pengguna ke dalam peran-peran khusus (misal: Read-Only, Editor, Admin) dan mengatur hak aksesnya langsung menggunakan perintah kontrol data SQL seperti GRANT dan REVOKE.
Validasi Sisi Server

(Server-side Validation): Jangan pernah mengandalkan kontrol akses di sisi aplikasi/frontend saja; setiap kueri ke basis data wajib diperiksa otorisasi perannya di sisi server (backend).

LEARN MORE

CONCLUSION

Authentication dan Authorization adalah dua pilar utama dalam sistem keamanan basis data yang bekerja secara berurutan. Authentication memastikan bahwa yang mengakses sistem adalah pihak yang sah, sedangkan Authorization memastikan pihak sah tersebut hanya mengakses data sesuai dengan wewenang yang diberikan. Tanpa kombinasi keduanya, basis data rentan terhadap akses tidak sah dan manipulasi data.

READ MORE

Thank You For Your Attention

SECURITY BASIS DATA